



File No.: EXP202209596

RESOLUTION FOR TERMINATION OF THE PROCEDURE DUE TO VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On February 22, 2024, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against BLU MANAGEMENT SPAIN, S.L. (hereinafter, the respondent), through the Agreement that is transcribed:

<<

File No.: EXP202209596

IMI Reference: A56ID 437951 - Case Register 550411

AGREEMENT TO INITIATE SANCTIONING PROCEEDINGS

From the actions taken by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: A.A.A. (hereinafter, the claimant) filed a complaint with the data protection authority of France. The complaint is directed against BLU MANAGEMENT SPAIN, S.L. with NIF B66500661 (hereinafter, BLU MANAGEMENT).

The reasons on which the complaint is based are as follows:

The claimant contacted BLU MANAGEMENT, which is a recruitment agency, to apply for a job around May 2021, and had a telephone interview with B.B.B. (hereinafter, the consultant of BLU MANAGEMENT).

Subsequently, on July 26, 2021, the claimant received a series of messages via WhatsApp (...), where the claimant had worked.

The person who sent these WhatsApp messages indicated that the one who provided her contact details was the consultant of BLU MANAGEMENT.

The claimant indicates that she had not given permission to BLU MANAGEMENT to share her data with third parties. For this reason, she contacted BLU MANAGEMENT on July 26, 27, and 30, 2021, having received a response from them, but considers that what they have done is not sufficient to address these facts.

Along with the complaint, the following is provided:

- Printout of an email sent by the claimant to contact@blueselection.com dated July 26, 2021, in which the claimant outlines the facts and requests that the email be forwarded to the company's Data Protection Officer (hereinafter, DPO), expressed in the following terms:

"T(...) message is aimed at the DPO of your company.

Dear Madam, Sir,

Tonight, I have been approached by a close friend of one of your employees who gave away my personal phone number.

Long story short, I was in touch with one of your employees from the recruitment team a couple of months ago. T(...) employee - I'll be happy to provide you (...) name - gave away my phone number to (...) friend so I can help (...) resolving (...) issues (...).

Your employee's friend contacted me by WhatsApp tonight and I was able to get clear confirmation that my interviewer from Bluselection was the one who gave my phone number away. Tchat transcript ready to be provided to you as proof.

I would like to highlight the fact that t(...) is a serious matter. First of all, I find quite alarming that your employees use your company data to resolving their friends' private matters. (...). Second, I certainly did not consent my data to be used for your employees' private matters. Third, I know quite well the GDPR and the scenario where an employee of a company uses personal data for (...) own sake or (...) friends' sake is definitely not allowed.

I want to be contacted urgently on t(...) matter that is unacceptable. You can contact me by phone (***)TELÉFONO.1) or by email in English or French.

If I don't hear from your DPO real soon, I will quick launch all procedures to sue your company.”

[Unofficial translation:

“This message is directed to the DPO of your company.

(...)

Tonight, I have been approached by (...) who gave my personal phone number away.

Long story short, I was in touch with one of your (...) from the recruitment team a couple of months ago. (...) — I'll be happy to provide his name — gave my phone number to his ***RELATIONSHIP.1 so I can help him (...).

The ***RELATIONSHIP.1 of your ***POSITION.1 contacted me by WhatsApp tonight and I was able to get a clear confirmation that my ***POSITION.2 from BluSelection was the one who gave my phone number away. I have a chat transcript ready to provide to you as proof.

I would like to highlight the fact that this is a serious matter. First of all, I find it quite alarming that your ***POSITION.1 use your company data to resolve their friends' private matters (...). Second, I certainly did not give permission for my data to be used by your ***POSITION.1 for private matters. Third, I know quite well the GDPR and the scenario where a ***POSITION.1 of a company uses personal data for (...) their own sake or (...) friends' sake is definitely not allowed.

I want to be contacted urgently on this matter that is unacceptable. You can contact me by phone (***)TELÉFONO.1) or by email in English or French.

If I don't hear from your DPO real soon, I will quickly launch all procedures to sue your company.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/18

Personal data for your own benefit or for that of your friends is definitely not allowed.

I want to be contacted urgently regarding this unacceptable matter.

You can reach me by phone (***)PHONE.1) or by email in English or French.

If I do not hear from your DPD very soon, I will quickly initiate all procedures to sue your company.”]

- Printout of the email sent by the claimant to ***EMAIL.1 dated July 27, 2021, in which the claimant confirms that they were contacted by phone by a ***POSITION.1 of BLUE MANAGEMENT and requests the exercise of their rights in the following terms:

“Thank you for your call today.

Following our conversation today, I was contacted yesterday evening by a friend of one of your former employees B.B.B.. had access to my data while (...) was an employee of yours and gave my personal phone number away to (...) friend (chat transcript attached).

I never consented for my data to be disclosed to third parties such as friends of your employees; hence, as I, the data subject, am a victim of a breach of my data, I request:

1- Immediate erasure of the data you hold about me. I also want a copy of these data that you should provide me with within 30 days from today as per the GDPR. T(...) is a Data Access Request.

2- I understand B.B.B. is no longer one of your employees. However, it raises some concerns. I would like to know the actions you are going to take to make sure t(...) kind of scenario never happens again to someone else.

3- As there is a violation of my rights (you have not been able to hold my data safely and avoid your former employee from sending them away), I would like to be compensated.

Failing to respond to my requests within 30 days from today will result in a complaint filed with the AEPD. They will then decide what compensation is fair for t(...) data breach.”

[Unofficial translation:

“Thank you for your call today.

After our conversation today, I was contacted yesterday evening by a ***RELATIONSHIP.1 (...) of your former ***POSITION.1 B.B.B.. had access to my data while he was your ***POSITION.1 and gave my personal phone number to his ***RELATIONSHIP.1 (chat transcript attached).

I never consented for my data to be disclosed to third parties, such as friends of your ***POSITION.1; therefore, as I, the data subject, am a victim of a breach of my data, I request:

1- Immediate erasure of the data you hold about me. I also want a copy of these data that you must provide me within 30 days from today according to the GDPR. This is a data access request. I understand that B.B.B. is no longer one of your ***POSITION.1. However, it raises some concerns. I would like to know the actions you are going to take to ensure that this kind of scenario never happens to someone else.

3- As there is a violation of my rights (you have not been able to keep my data securely and prevent your ***POSITION.1 from sending them away), I would like to receive compensation. Not responding to my requests within 30 days from today will result in a complaint filed with the AEPD. They will then decide what compensation is fair for this data breach.”]

It is noted that this email is accompanied by a text document that the claimant indicates is the transcript of the WhatsApp conversation mentioned within the body of the email.

- Printout of the email sent by ***EMAIL.1 to the claimant, dated July 27, 2021, in which the receipt of the previous email is confirmed in the following terms:

“Hi A.A.A.,

Thank you for your time during our phone call and the information you gave me.

By my email response, I confirm the receipt of your requests.

As mentioned on our call, I will directly transfer t(...) topic to my management and our Legal advisor.

We will get back to you as soon as possible.

I wish you a pleasant day.

Kind regards,”

[Unofficial translation:

“Hello A.A.A.,

Thank you for your time during our phone call and the information you provided.

With my email response, I confirm the receipt of your requests.

As we discussed in our call, I will transfer this matter directly to my management and our legal advisor.

We will respond to you as soon as possible.

I wish you a pleasant day.

Best regards,”]

- Printout of the email sent by ***EMAIL.2 to the claimant, dated July 30, 2021, in which the following information is provided:

“First of all, please accept our apologies for the unwanted events, of which we found out through your email and the telephone conversation held on July 26th with our Recruitment Manager, C.C.C..

We would like to inform you that B.B.B. has not been a member of t(...) organization since last June 30. That on the date he left our Company, all access permissions to the candidates database were withdrawn and (...) email account has been blocked. Additionally, we have contacted B.B.B. with whom we have signed a confidentiality and non-competition agreement and he has certified the destruction of (...) contact information (name and mobile phone number).

Likewise, we inform you that, to avoid t(...) situation from occurring again, all Blu Selection employees who terminate their contracts or are dismissed will sign a Confidentiality and Non-Attendance Agreement, so as to guarantee that they do not have in their possession personal data of which our company is a Data

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/18

Controller. In addition, we are going to initiate a Data Protection Impact Assessment and the activity of employees regarding access to personal data will be monitored.

In relation to your request to exercise your right of access to the personal data held by Blu Selection, according to arts. 15 and 13 respectively of the GDPR and the Spanish Data Protection Act, we indicate that we only have the personal data included in your resume (identification data, academic data, and data on professional experience) that you sent us on May 1, 2021, in order to participate in the selection processes managed by this company. We attach a copy of it.

Finally, we inform you that we have proceeded, as you have requested, to cancel and erase all your personal data for which Blu Selection is Controller in accordance with the GDPR and the Spanish Data Protection Act, including all emails and other messages and communication received.

Serve this communication as a means of proof of the cancellation of your personal data.

[Unofficial Translation:

"First of all, please accept our apologies for these unwanted events, of which we became aware through your email and the telephone conversation held on July 26 with our Recruitment Manager, C.C.C.

We would like to inform you that B.B.B. has not been a member of this organization since June 30. On the date he left our Company, all access permissions to the candidate database were revoked, and his email account has been blocked. Additionally, we have contacted B.B.B., with whom we have signed a confidentiality and non-compete agreement, and he has certified the destruction of your contact information (name and mobile phone number).

Furthermore, we inform you that, to prevent this situation from occurring again, all ***POSITION.1 of Blu Selection who terminate their contracts or are dismissed will sign a Confidentiality and Non-Solicitation Agreement, in order to ensure that they do not hold personal data for which our company is Data Controller. Moreover, we are going to initiate a Data Protection Impact Assessment and the activity of ***POSITION.1 regarding access to personal data will be monitored.

In relation to your request to exercise your right of access to the personal data held by Blu Selection, according to articles 15 and 13 respectively of the GDPR and the Spanish Data Protection Act, we indicate that we only have the personal data included in your resume (identification data, academic data, and data on professional experience) that you sent us on May 1, 2021, in order to participate in the selection processes managed by this company. We attach a copy of it.

Finally, we inform you that we have proceeded, as you have requested, to cancel and erase all your personal data for which Blu Selection is Data Controller in accordance with the GDPR and the Spanish Data Protection Act, including all emails and other messages and communications received.

Serve this communication as a means of proof of the cancellation of your personal data."]

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/18

It is noted that this email is accompanied by a document in PDF format titled "****URL.1".

- Printout of an email sent by the claimant to ***EMAIL.2 dated July 30, 2021, in response to the previous email, containing the following content:

"Dear Data Protection Officer,

Thank you for your email.

I appreciate you fulfilled most of my requests within a short period of time.

The content of your email is an admission of liability on your part (especially paragraph 3). In fact, your employee at that time (up until June 30th, 2021) was able to circumvent your systems to extract my data without your knowledge and to my prejudice. Even though you should have performed the DPIA way before such a critical situation happened to prevent it from occurring, I appreciate you are now willing to assess your company.

Nonetheless, as the employer of B.B.B., you failed to store my data safely. As a victim of a prejudice, I ask for reasonable compensation for your failure.

If I do not hear from you before August 27th, 2021, or if your final answer stands where it is at t(...) point, I will have to contact the AEPD to make them aware of t(...) situation and ask for their guidance to find an amicable solution.

I look forward to hearing from you."

[Unofficial translation:

"Estimado delegado de protección de datos:

Gracias por su correo electrónico.

Agradezco que haya cumplido la mayoría de mis peticiones en un corto período de tiempo.

El contenido de su correo electrónico es una admisión de responsabilidad por su parte (especialmente el párrafo 3). De hecho, su ***PUESTO.1 en ese momento (hasta el 30 de junio de 2021) pudo eludir sus sistemas para extraer mis datos sin su conocimiento y para mi perjuicio. A pesar de que debería haber realizado la DPIA mucho antes de que sucediera una situación tan crítica para evitar que ocurra, aprecio que ahora esté dispuesto a evaluar su empresa.

No obstante, como ***PUESTO.1 de B.B.B. no almacenó mis datos de forma segura. Como víctima de un perjuicio le pido una compensación razonable por su fallo.

Si no tengo noticias de usted antes del 27 de agosto de 2021 o si su respuesta final sigue en este mismo punto, tendré que contactar con la AEPD para informarles de esta situación y pedirles su orientación para encontrar una solución amistosa.

Espero saber de usted.”]

- Transcript of a WhatsApp conversation dated July 26, 2021, in which, among other information, the following is indicated:

“26/07/2021, 20:39 - ***TELÉFONO.2: Hello! I hope you are doing good. My name is D.D.D. and I got your phone number from a friend who did an interview with you. Since he knew that I had problems with my ***CUENTA.1 he kindly gave me your number. The problem with my business and my private account is, C/ Jorge Juan, 6 www.aepd.es 28001 – Madrid sedeagpd.gob.es
7/18

that I got permanently banned from ***CUENTA.1. I do not know why t(...) happened since I used my accounts in a normal way. When I ask for help or contact the support they will not give me an answer or solutions for t(...) problem, so I wanted to ask you if you know a way to solve t(...) misunderstanding. It would mean a lot if you could take the time to answer. Thank you in advance.

26/07/2021, 20:39 - ***TELÉFONO.2: Kind Regards

26/07/2021, 20:39 - ***TELÉFONO.2: D.D.D.

26/07/2021, 20:42 - A.A.A.: Hi. What is the name of your friend who supposedly did an interview with me?

26/07/2021, 20:46 - ***TELÉFONO.2: I will ask for permission to give out (...) name and come back to you in a second.

26/07/2021, 20:46 - A.A.A.: If you don't tell me how you got t(...) number I won't be able to assist

26/07/2021, 20:47 - ***TELÉFONO.2: I fully understand that, I just want to make sure my friend is ok with t(...)

26/07/2021, 20:48 - A.A.A.: Well, if your friend gave you my private number it means he is also my friend. That shouldn't be an issue to provide (...) name

26/07/2021, 20:49 - ***TELÉFONO.2: He got your number from an interview with (...). You contacted the company he worked in, so you do not know (...) personally

26/07/2021, 20:50 - A.A.A.: What company?

26/07/2021, 20:51 - ***TELÉFONO.2: As soon as my friend will give me the Ok I will be transparent with all the information you need

26/07/2021, 20:53 - A.A.A.: Look mate. You are coming out of the blue requesting my help but you don't want to tell me where you got my private number from. If I don't have at least the name of the company and ideally the name of the person who gave it to you within 5min, you are gonna have to deal with ***CUENTA.1 directly I am afraid

26/07/2021, 20:55 - ***TELÉFONO.2: ok I just called (...), the company is called blue selection

26/07/2021, 20:56 - A.A.A.: In Spain

26/07/2021, 20:56 - A.A.A.: ?

26/07/2021, 20:56 - ***TELÉFONO.2: yes”

...

“26/07/2021, 21:10 - A.A.A.: Is it B.B.B. who gave you my number?

26/07/2021, 21:11 - ***TELÉFONO.2: I agreed with (...) that I do not give the name away, I also do not know your name or anything

26/07/2021, 21:11 - A.A.A.: So t(...) is (...)?

26/07/2021, 21:12 - ***TELÉFONO.2: Why is t(...) necessary?

26/07/2021, 21:12 - A.A.A.: Because I don't know you

26/07/2021, 21:13 - A.A.A.: I need some reassurance here

26/07/2021, 21:13 - ***TELÉFONO.2: I fully understand, but you know that my request is legit since I know the name of the company

26/07/2021, 21:14 - A.A.A.: I had contact only with (...), so t(...) is (...)

26/07/2021, 21:15 - ***TELÉFONO.2: I will not give away the name of the person, I know that I cannot give you any value for helping me

26/07/2021, 21:15 - ***TELÉFONO.2: I could pay you if it is possible to solve t(...) problem

C/ Jorge Juan, 6 www.aepd.es 28001 – Madrid sedeagpd.gob.es

8/18

26/07/2021, 21:17 - A.A.A.: Look mate you are going too far. T(...) has to stop. I am no longer an employee of ***CUENTA.1 and surely did not consent for my personal number to be given away. Please contact ***CUENTA.1

26/07/2021, 21:17 - ***TELÉFONO.2: Ok, I am sorry for disturbing you. I will delete your number right away.

26/07/2021, 21:19 - You blocked t(...) contact. Tap to unblock.”

[Unofficial translation:

“26.7.2021, 20:39 — ***TELÉFONO.2: Hello! I hope you are well. My name is D.D.D. and I obtained your phone number from a ***PARENTESCO.1 who interviewed you. Since they knew I was having problems with my ***CUENTA.1 account, they kindly gave me your number. The issue with my business and my private account is that ***CUENTA.1 permanently prohibited me from using it. I don't know why this happened because I used my accounts in a normal way. When I ask for help or contact support, they do not provide me with a response or solutions for this problem, so I wanted to ask you if you know a way to resolve this misunderstanding. It would mean a lot if you could take the time to respond. Thank you in advance.

26.7.2021, 20:39 — ***TELÉFONO.2: Best regards

26.7.2021, 20:39 — ***TELÉFONO.2: D.D.D.

26.7.2021, 20:42 — A.A.A.: Hello. What is the name of your ***PARENTESCO.1 who supposedly interviewed me?

26.7.2021, 20:46 — ***TELÉFONO.2: I will ask for permission to give their name and I will reply in a second.

26.7.2021, 20:46 — A.A.A.: If you don't tell me how you got this number, I won't be able to help you.

26.7.2021, 20:47 — ***TELÉFONO.2: I completely understand. I just want to make sure that my ***PARENTESCO.1 agrees with this.

26.7.2021, 20:48 — A.A.A.: Well, if your ***PARENTESCO.1 gave you my private number, it means they are also my ***PARENTESCO.1. That shouldn't be a problem to provide their name.

26.7.2021, 20:49 — ***TELÉFONO.2: I got your number from an interview with him. He contacted the company where he worked, so he doesn't know you personally.

26.7.2021, 20:50 — A.A.A.: What company?

26.7.2021, 20:51 — ***TELÉFONO.2: As soon as my ***PARENTESCO.1 gives me the Ok, I will be transparent with all the information you need.

26.7.2021, 20:53 — A.A.A.: Look ***PARENTESCO.1. You come out of nowhere asking for my help but don't want to tell me where you got my private number. If I don't have at least the name of the company and ideally the name of the person who gave it to you within 5 minutes, you will have to deal with ***CUENTA.1 directly.

26.7.2021, 20:55 — ***TELÉFONO.2: OK, I just called him, the company is called blu selection.

26.7.2021, 20:56 — A.A.A.: In Spain

26.7.2021, 20:56 — A.A.A.:

26.7.2021, 20:56 — ***TELÉFONO.2: yes”

...

“26.7.2021, 21:10 — A.A.A.: Is it B.B.B. who gave you my number?

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/18

26.7.2021, 21:11 — ***PHONE.2: I agreed with him not to give his name, I also don't know your name or anything.

26.7.2021, 21:11 — A.A.A.: So it's him?

26.7.2021, 21:12 — ***PHONE.2: Why is it necessary?

26.7.2021, 21:12 — A.A.A.: Because I don't know you.

26.7.2021, 21:13 — A.A.A.: I need a little security here.

26.7.2021, 21:13 — ***PHONE.2: I completely understand, but you know my request is legitimate since I know the name of the company.

26.7.2021, 21:14 — A.A.A.: I only had contact with him, so it's him.

26.7.2021, 21:15 — ***PHONE.2: I will not give the name of the person, I know I cannot give you any value for helping me.

26.7.2021, 21:15 — ***PHONE.2: I could pay you if it's possible to resolve this issue.

26.7.2021, 21:17 — A.A.A.: Look, friend, you are going too far. This has to stop. I am no longer an employee of ***ACCOUNT.1 and I am sure I did not consent to my personal number being given to others. Please contact ***ACCOUNT.1.

26.7.2021, 21:17 — ***PHONE.2: OK, I'm sorry to bother you. I will delete your number immediately.

26/07/2021, 21:19 — You have blocked this contact. Tap to unblock.”

SECOND: Through the “Internal Market Information System” (hereinafter IMI System), regulated by Regulation (EU) No. 1024/2012 of the European Parliament and of the Council, of 25 October 2012 (IMI Regulation), whose objective is to promote cross-border administrative cooperation, mutual assistance between Member States, and the exchange of information, the aforementioned complaint was transmitted on 14 September 2022 and was registered with the Spanish Agency for Data Protection (AEPD) on 15 September 2022. The transfer of this complaint to the AEPD was carried out in accordance with the provisions of Article 56 of Regulation (EU) 2016/679 of the European Parliament and of the Council, of 27/04/2016, regarding the Protection of Natural Persons with regard to the Processing of Personal Data and the Free Movement of such Data (hereinafter, GDPR), taking into account its cross-border nature and that this Agency is competent to act as the lead supervisory authority, given that BLU MANAGEMENT has its sole establishment in Spain.

According to the information incorporated into the IMI System, in accordance with the provisions of Article 60 of the GDPR, the data protection authority of France acts as an interested authority, in accordance with the provisions of Article 4.22) letter c) of the GDPR, as it is the supervisory authority to which the complaint has been submitted, without other supervisory authorities having declared themselves interested in the present procedure.

THIRD: On 10 February 2023, in accordance with the then-current Article 64 of Organic Law 3/2018, of 5 December, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the complaint submitted by the complainant was admitted for processing.

FOURTH: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts at C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/18

issue, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

On June 30, 2023, a document was submitted to the AEPD on behalf of BLU MANAGEMENT in response to an information request, which included, among other things, the following information:

- A copy of the email sent by ***EMAIL.2 to the complainant, dated July 30, 2021, which had already

been provided by the CNIL along with the complaint. Along with it, a certificate is provided stating that this email was sent on July 30, 2021.

On September 4, 2023, a document was submitted to the AEPD on behalf of BLU MANAGEMENT in response to an information request, which included, among other things, the following information:

- It is indicated that a Data Protection Impact Assessment (hereinafter, DPIA) was conducted after receiving the request from the complainant. A copy of the DPIA for the data processing that "consists of conducting interviews with candidates for positions offered by third-party clients of Blu Management Spain, S.L." is provided. From this DPIA, the conclusion is drawn that it is not necessary to carry out a prior consultation with the competent authority.

- A copy of the analysis of the risks related to this processing activity and the applicable security measures is provided, which includes whether they are already implemented or not and the date of implementation of the measure.

- Regarding the causes of this incident, the following is indicated:

"During the interview conducted with the complainant, Mr. B.B.B. was present in his capacity as an intern along with the Selection Consultant, and we understand that during the interview he was able to see the mobile phone number of (...) and provide this information to a friend, who was the one who contacted the complainant on July 26, 2021, a date on which B.B.B. no longer belonged to Blu as an Erasmus+ intern, as he voluntarily left his internship on June 16, 2021, as evidenced by the email sent by the Recruitment Manager, C.C.C. to E.E.E., responsible for Erasmus+ at ***UNIVERSITY.1.

Upon becoming aware through the email from the complainant, we made the appropriate inquiries, contacting B.B.B. to learn firsthand about the events that occurred, who confirmed to us that during the interview he attended, he noted the mobile phone number of the complainant to provide it to "(...)".

For all the above, this party understands that it is not appropriate to provide any contract regarding the maintenance of the Information Systems, as they have not been involved."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/18

- Regarding the measures adopted to modify security incidents such as the one that occurred, the following is indicated:

"It was internally agreed that in all selection processes attended by interns, they would be prohibited from accessing with tablets or mobile phones and would always be accompanied by a Selection Consultant who would have access to the candidates' data, once they had given their consent for the selection processes. Additionally, all ***POSITION.1 of Blu sign an NDA regarding all the data they handle in the exercise of their functions. Finally, the employment contracts were modified to include a clause regarding the "Use of information and technology equipment and devices."

- Regarding the lack of notification of this security incident to the AEPD, the following is indicated:

"In accordance with the exceptions set forth in Article 34 of the GDPR, which outlines a series of cases in which this communication will not be mandatory, this company opted not to notify the security breach, as, subsequent to it, Blu Selection took technical and organizational measures to ensure that there is no possibility of the high risk materializing and, especially considering that it only occurred concerning one individual and all actions were directed to prevent the events from recurring."

FIFTH: Business volume or activity: According to the inquiry made on September 8, 2023, in the Monitoriza service of Axesor (<https://monitoriza.axesor.es/>), BLU MANAGEMENT SPAIN SL is a company of the "Autonomous" type with a sales volume in the fiscal year 2020 of ***AMOUNT.1 euros.

SIXTH: On January 8, 2024, the Director of the AEPD adopted a draft agreement to initiate sanctioning proceedings. Following the process established in Article 60 of the GDPR, on January 18, 2024, the aforementioned draft was transmitted through the IMI system, and the interested authorities were informed that they had four weeks from that moment to submit pertinent and motivated objections. The processing period of the proceedings was automatically suspended during these four weeks, in accordance with the provisions of Article 64 of the LOPDGGD.

Within the deadline for this purpose, the interested control authorities did not submit pertinent and motivated objections in this regard, so it is considered that all authorities agree with this draft and are bound by it, in accordance with the provisions of Article 60 of the GDPR.

LEGAL GROUNDS

I

Competence

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/18

In accordance with the powers granted to each supervisory authority by Article 58.2 and 60 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure. Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

In the present case, in accordance with the provisions of Articles 4.1 and 4.2 of the GDPR, it is established that there has been a processing of personal data, given that BLU MANAGEMENT collects and retains, among others, the following personal data of individuals: name and phone number, among other processing activities.

BLU MANAGEMENT carries out this activity in its capacity as data controller, as it determines the purposes and means of such activity, pursuant to Article 4.7 of the GDPR. Furthermore, this is a cross-border processing, as BLU MANAGEMENT is established in Spain, although it provides services to other countries in the European Union.

Article 4, paragraph 12 of the GDPR broadly defines "personal data security breaches" (hereinafter, security breach) as "all breaches of security that lead to the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or to the unauthorized communication or access to such data."

In this case, there is a personal data security breach under the circumstances mentioned above, categorized as a confidentiality breach, as a friend of BLU MANAGEMENT allegedly used their position to obtain the phone number of the complainant and communicated it to a third party, who then contacted the complainant via WhatsApp.

Within the principles of processing provided for in Article 5 of the GDPR, the integrity and confidentiality of personal data are guaranteed in paragraph 1.f) of Article 5 of the GDPR.

III

Principle of Integrity and Confidentiality

Article 5.1.f) "Principles relating to processing" of the GDPR states:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/18

"1. Personal data shall be:

(...)

f) processed in such a manner that ensures an appropriate security of the personal data, including

protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by means of the application of appropriate technical or organizational measures ('integrity and confidentiality')."

In this case, it is established that the personal data of the affected individuals, contained in the database of BLU MANAGEMENT, were improperly exposed to a third party, as the complainant has stated that they received a communication via WhatsApp from a third party, informing them that they had obtained their data (name and phone number) from a person working at BLU MANAGEMENT. Additionally, BLU MANAGEMENT has stated that, upon contacting the person who allegedly shared the phone number, they confirmed that they accessed the complainant's phone number and communicated it to that third party.

For its part, BLU MANAGEMENT has informed the complainant that the person who leaked the data has certified the destruction of their contact information.

Therefore, in accordance with the evidence available at this stage of the initiation of sanctioning procedure, and without prejudice to the outcome of the investigation, it is considered that the known facts could constitute an infringement attributable to BLU MANAGEMENT for violation of Article 5.1.f) of the GDPR.

IV

Classification of the Infringement of Article 5.1.f) of the GDPR

If confirmed, the aforementioned infringement of Article 5.1.f) of the GDPR could constitute the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to 4% of the total annual global turnover of the preceding financial year, whichever is higher:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

For the purposes of the limitation period, Article 72 "Very serious infringements" of the LOPDGDD indicates:

"1. Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following shall be considered very serious and shall be subject to a three-year limitation period for infringements that constitute a substantial violation of the articles mentioned therein, and in particular the following:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/18

a) The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

V

Proposal for sanction for the infringement of Article 5.1.f) of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered that the balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 5.1.f) of the GDPR, allows for an initial sanction of €2,000 (two thousand euros).

VI

Imposition of measures

If the infringement is confirmed, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to bring processing operations into compliance with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time..." in the resolution adopted, BLU MANAGEMENT

may be required to notify this Agency within SIX MONTHS that it has adopted the appropriate measures to adjust its actions to the regulations mentioned in this act, without prejudice to others that may arise from the instruction of the procedure.

The imposition of these measures is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

It is warned that failure to comply with the possible order to adopt measures imposed by this agency in the resolution that concludes this procedure may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, which may motivate the opening of a further sanctioning administrative procedure.

Therefore, in light of the above, by the Director of the Spanish Agency for Data Protection,
IT IS AGREED:

FIRST: TO INITIATE SANCTIONING PROCEDURE against BLU MANAGEMENT SPAIN, S.L., with NIF B66500661, for the alleged infringement of Article 5.1.f) of the GDPR, classified in Article 83.5 of the GDPR.

SECOND: TO APPOINT R.R.R. as instructor and S.S.S. as secretary, indicating that they may be challenged, if applicable, in accordance with the provisions of Articles 23 and 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

15/18

THIRD: TO INCORPORATE into the file, for evidentiary purposes, the documentation from the IMI that has led to the prior investigation actions, as well as the documents obtained and generated by the General Subdirectorate of Data Inspection in the actions prior to the initiation of this procedure and the documentation from the IMI regarding the draft decision.

FOURTH: THAT for the purposes provided in Article 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the sanction that may correspond would be €2,000, without prejudice to what results from the instruction.

FIFTH: TO NOTIFY this agreement to BLU MANAGEMENT SPAIN, S.L., with NIF B66500661, granting a hearing period of ten working days for it to submit allegations and present any evidence it deems appropriate. In its written allegations, it must provide its NIF and the file number indicated in the heading of this document.

If no allegations are made within the stipulated period regarding this initiation agreement, it may be considered a proposal for resolution, as established in Article 64.2.f) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP).

In accordance with the provisions of Article 85 of the LPACAP, it may acknowledge its responsibility within the period granted for the formulation of allegations to this initiation agreement; this will entail a reduction of 20% of the sanction that may be imposed in this procedure. With the application of this reduction, the sanction would be set at €1,600, resolving the procedure with the imposition of this sanction.

Similarly, it may, at any time prior to the resolution of this procedure, make voluntary payment of the proposed sanction, which will entail a reduction of 20% of its amount. With the application of this reduction, the sanction would be set at €1,600, and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

The reduction for voluntary payment of the sanction is cumulative with the one corresponding to the acknowledgment of responsibility, provided that this acknowledgment of responsibility is made within the period granted to formulate allegations to the opening of the procedure. The voluntary payment of the amount referred to in the previous paragraph may be made at any time prior to the resolution. In this case, if both reductions are applicable, the amount of the sanction would be set at €1,200.

In any case, the effectiveness of either of the two mentioned reductions will be conditioned upon the withdrawal or waiver of any action or appeal in the administrative route against the sanction.

In the event that it opts to proceed with the voluntary payment of any of the amounts indicated above (€1,600 or €1,200), it must make it effective through its

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/18

Deposit into account no. IBAN: ES00-0000-0000-0000-0000 opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason for the reduction of the amount to which it is entitled.

Furthermore, you must send the proof of deposit to the General Subdirectorate of Inspection to continue with the procedure in accordance with the amount deposited.

The procedure will have a maximum duration of twelve months from the date of the initiation agreement. After this period, it will expire, and consequently, the file will be archived; in accordance with the provisions of Article 64 of the LOPDGDD.

Finally, it is noted that according to the provisions of Article 112.1 of the LPACAP, there is no administrative appeal against this act.

935-30102023

Mar España Martí

Director of the Spanish Agency for Data Protection

>>

SECOND: On February 29, 2024, the party being claimed has proceeded to pay the fine in the amount of 1200 euros, making use of the two reductions provided for in the previously transcribed Initiation Agreement, which implies the acknowledgment of responsibility.

THIRD: The payment made, within the period granted to submit allegations regarding the opening of the procedure, entails the waiver of any action or administrative appeal against the fine and the acknowledgment of responsibility concerning the facts referred to in the Initiation Agreement and its legal qualification.

FOURTH: In the previously transcribed Initiation Agreement, it was indicated that, if the infringement is confirmed, measures could be imposed on the responsible party to adjust their actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time frame...".

Having acknowledged the responsibility for the infringement, the imposition of the measures included in the Initiation Agreement is warranted.

LEGAL GROUNDS

I

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/18

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this

organic law, by the regulatory provisions issued in its development, and, insofar as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), under the heading "Termination in sanctioning procedures" provides as follows:

"1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely of a pecuniary nature or when it is possible to impose a pecuniary sanction and another of a non-pecuniary nature but the impropriety of the latter has been justified, voluntary payment by the presumed responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for the damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely of a pecuniary nature, the competent authority to resolve the procedure shall apply reductions of at least 20% on the amount of the proposed sanction, which shall be cumulative. The aforementioned reductions must be determined in the notification of initiation of the procedure, and their effectiveness shall be conditioned on the withdrawal or waiver of any action or administrative appeal against the sanction. The percentage of reduction provided in this section may be increased by regulation."

In accordance with the above,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE the termination of procedure EXP202209596, in accordance with the provisions of Article 85 of the LPACAP.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/18

SECOND: TO ORDER BLU MANAGEMENT SPAIN, S.L. to notify the Agency within 6 months from the date this resolution becomes final and enforceable, of the adoption of the measures described in the legal grounds of the Initiation Agreement transcribed in this resolution.

THIRD: TO NOTIFY this resolution to BLU MANAGEMENT SPAIN, S.L.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within a period of two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

1259-151024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es